Plano de Respostas aos Riscos

Projeto: SmartAce – Grupo Enrolados

Data: 04/11/2026

Versão: 1.1

1. Introdução

Este plano estabelece as respostas para os doze riscos do projeto: os seis registrados no Plano de Gerenciamento de Riscos (R1 a R6) e os seis incorporados na versão 1.1 a partir da varredura de segurança do Aikido Security (R7 a R12). O escopo considera o sensor MPU-6050 conectado ao ESP32, a transmissão dos golpes por Bluetooth SPP, o aplicativo Android, a persistência local com Room, a API Node.js/MySQL usada para sincronização entre dispositivos e os componentes Python de visão computacional e dashboard.

As classificações de probabilidade, impacto e nível final foram mantidas conforme o documento-base. “Mitigação parcial” indica que há controles no código ou alterações incluídas neste pacote, mas ainda faltam testes de integração ou confirmação operacional; não equivale a declarar o risco encerrado.

Os riscos R7 a R12 decorrem da varredura do Aikido Security, com 15 achados abertos (3 críticos, 4 altos, 6 médios e 2 baixos), agrupados por tema e componente. Esforços são os estimados pelo Aikido.

Ordem de atenção: R2, R7 e R8 (Extremo) → R1, R9, R10 e R11 (Alto) → R3, R4, R5 e R12 (Médio) → R6 (Baixo).

Critério de conclusão: Cada resposta só será marcada como concluída após execução dos testes previstos e registro da evidência (log, resultado de teste, revisão ou issue) no repositório do projeto.

2. Tabela de Respostas aos Riscos

Esta tabela serve como o núcleo do plano, detalhando a resposta para cada risco priorizado.

ID do Risco	Descrição do Risco	Nível do Risco (Prioridade)	Estratégia de Resposta	Ações Específicas Planejadas	Responsável pela Ação	Prazo para Implementação	Status
R1	Vazamento de dados ou credenciais de usuários no banco de dados MySQL (Organizacional/LGPD)	**Alto**	**Mitigar**	1.Remover “.env” de pacotes e versionamento; rotacionar senha MySQL e JWT. 2.Restringir CORS, limitar tamanho e taxa de sincronização, manter SQL parametrizado e JWT com algoritimo explicito. 3.Usar conta MySQL de menor privilégio; exigir HTTPS/VPN antes de sair da LAN.	Murilo Vieira Apoio: Iury Xavier	16/10/2026	Concluído
R2	Queda continua do Bluetooth SPP ou	**Extremo**	**Mitigar**	1.Executar testes em quadra, por duração e com	Lilian Conde Apoio:	31/10/2026	Em andament

ID do Risco	Descrição do Risco	Nível do Risco (Prioridade)	Estratégia de Resposta	Ações Específicas Planejadas	Responsável pela Ação	Prazo para Implementação	Status
	interferência de RF 2,4 GHz impede a coleta de telemetria durante o treino.			interferência variável. 2.Implementar reconexão controlada e avaliar buffer/reenvio de amostras sem bloquear o treino. 3.Registrar quedas e verificar recuperação após desconexão.	Guilherme Barioni		o
R3	Lentidão da API Express/MySQL ou falha de sincronização com o banco Android Room.	**Médio**	**Mitigar (contingência offline)**	1) Preservar o Room como fonte local durante indisponibilidade. 2) Testar repetição de sincronização, duplicidade, rollback e recuperação do servidor. 3) Medir latência e registrar erros sem interromper o treino.	Iury Xavier Apoio: Marcus Duque	28/10/2026	Concluído
R4	Perda isolada de	**Médio**	**Mitigar**	1) Testar desconexão	Iury Xavier	31/10/2026	Em

ID do Risco	Descrição do Risco	Nível do Risco (Prioridade)	Estratégia de Resposta	Ações Específicas Planejadas	Responsável pela Ação	Prazo para Implementação	Status
	uma ou duas amostras na leitura I2C do MPU-6050, sem afetar a classificação.			momentânea, ruído e mau contato I2C. 2) Confirmar que quadros incompletos sejam descartados e contados, sem alimentar a classificação. 3) Registrar taxa de falha e recalibrar após mudanças físicas.			andamento
R5	Falha grave do firmware do ESP32 que interrompa o funcionamento da raquete.	**Médio (probabilidade muito baixa; impacto muito alto)**	**Mitigar**	1) Testar inicialização do sensor, alocação de memória e execução prolongada. 2) Revisar recuperação segura, watchdog e reinicialização controlada. 3) Manter firmware conhecido e procedimento documentado de regravação.	Marcus Duque	06/11/2026	Em Andamento

ID do Risco	Descrição do Risco	Nível do Risco (Prioridade)	Estratégia de Resposta	Ações Específicas Planejadas	Responsável pela Ação	Prazo para Implementação	Status
R6	Inconsistências visuais ou bugs estéticos no aplicativo Android.	**Baixo**	**Mitigar(Rotina)**	1) Aplicar checklist de telas, cores, contraste e botão voltar. 2) Realizar teste rápido nos fluxos de login, treino, desafio e estatísticas. 3) Registrar regressões visuais no backlog, sem bloquear correções críticas.	Guilherme Barioni	Continuo	Monitoramento de rotina
R7	Exploração de falhas de corrupção de memória nas bibliotecas Python opencv-python, pillow e numpy (heap overflow e ponteiro não confiável), com possibilidade de	**Extremo (Aikido: Crítico)**	**Mitigar**	1) Atualizar opencv-python, pillow e numpy para as versões corrigidas e fixar as versões no requirements.txt	Marcus Duque Apoio: Murilo Vieira	06/11/2026	Concluído

ID do Risco	Descrição do Risco	Nível do Risco (Prioridade)	Estratégia de Resposta	Ações Específicas Planejadas	Responsável pela Ação	Prazo para Implementação	Status
	negação de serviço ou execução remota de código ao processar imagens e vídeos.						
R8	Injeção de SQL em versões vulneráveis das bibliotecas Python PyMySQL (crítico) e pandas (baixo), com risco de leitura ou alteração indevida de dados no MySQL (Organizacional/LGPD).	**Extremo (Aikido: Crítico)**	**Mitigar**	1) Atualizar PyMySQL e pandas para as versões corrigidas e fixar as versões.	Murilo Vieira Apoio: Iury Xavier	06/11/2026	Concluído
R9	Backend Node.js/Express sem cabeçalhos de segurança HTTP	**Alto (Aikido: Alto)**	**Mitigar**	1) Aplicar a correção sugerida pelo Aikido para os cabeçalhos de segurança no server.js e conferir as	Iury Xavier Apoio: Murilo	06/11/2026	Concluído

ID do Risco	Descrição do Risco	Nível do Risco (Prioridade)	Estratégia de Resposta	Ações Específicas Planejadas	Responsável pela Ação	Prazo para Implementação	Status
	(server.js) e com dependências vulneráveis: multer (exceção não tratada) e raw-body (negação de serviço).			respostas HTTP.	Vieira		
R10	Envio de arquivos perigosos por falha na versão da biblioteca Streamlit usada na interface Python, permitindo que um atacante faça upload de conteúdo malicioso.	**Alto (Aikido: Alto)**	**Mitigar**	1) Atualizar o streamlit para a versão corrigida e fixar a versão.	Marcus Duque Apoio: Murilo Vieira	06/11/2026	Concluído
R11	Configuração insegura do aplicativo Android: validação	**Alto (Aikido: Alto)**	**Mitigar**	1) Exigir HTTPS com validação de certificado (Network Security Config), sem aceitar certificados	Guilherme Barioni Apoio: Lilian	06/11/2026	Em andamento

ID do Risco	Descrição do Risco	Nível do Risco (Prioridade)	Estratégia de Resposta	Ações Específicas Planejadas	Responsável pela Ação	Prazo para Implementação	Status
	inadequada de certificado SSL, componentes exportados e configuração de backup imprópria no AndroidManifest.xml, expondo a comunicação e os dados do app.			não validados nem tráfego em texto claro fora do desenvolvimento. 2) Definir android:exported="false" nos componentes que não precisam ser acessados por outros apps e proteger os demais com permissão. 3) Revisar a configuração de backup para excluir dados sensíveis, em conjunto com a exclusão do token já feita em R1.	Conde		
R12	Requisições HTTP com entrada controlável pelo usuário (SSRF) em app.py e VisaoComputacionalClient.java, e	**Médio (Aikido: Médio)**	**Mitigar**	1) Validar os destinos das requisições com lista de hosts permitidos, bloqueando IPs internos e redirecionamentos. 2) Trocar a exibição do stacktrace em Treino.java	Lilian Conde Apoio: Marcus Duque	06/11/2026	Em andamento

ID do Risco	Descrição do Risco	Nível do Risco (Prioridade)	Estratégia de Resposta	Ações Específicas Planejadas	Responsável pela Ação	Prazo para Implementação	Status
	exposição de stacktrace ao usuário final em Treino.java.			por mensagem genérica, registrando o detalhe apenas em log.			

3. Detalhamento das Estratégias de Resposta

Os gatilhos abaixo indicam quando a equipe deve executar a contingência. As respostas técnicas que já aparecem no código são identificadas como controles existentes; os itens restantes precisam de teste ou implementação.

3.1. R1 — Vazamento de dados ou credenciais

Gatilho de acionamento: Credencial exposta, acesso a dados de outra conta, origem web inesperada autorizada ou tentativa anormal de acesso.

Resposta/contingência: Bloquear temporariamente o acesso externo, rotacionar JWT_SECRET e senha MySQL, revisar logs e verificar escopo do incidente. Confirmar que cada consulta de sincronização usa o usuário derivado do token autenticado.

Situação observada no código: Hash bcrypt no backend, consultas parametrizadas, validação JWT e rate limit de autenticação. Incluídos nesta revisão: CORS sem curinga, limite de JSON de 4 MB, rate limit de sincronização, Cache-Control no-store e exclusão do token remoto dos backups Android.

Critério de encerramento: Segredos rotacionados, `.env` fora dos artefatos, testes de acesso cruzado entre duas contas aprovados e plano de transporte seguro (HTTPS/VPN) definido antes de qualquer exposição fora da LAN.

3.2. R2 — Queda de Bluetooth SPP / RF 2,4 GHz

Gatilho de acionamento: Desconexão durante um treino ou perda de amostras que torne a telemetria incompleta.

Resposta/contingência: Informar o estado de desconexão, preservar o treino local e permitir reconexão sem encerrar a atividade. Implementar tentativa de reconexão com espera progressiva e avaliar buffer de amostras no ESP32 se os testes confirmarem perdas.

Situação observada no código: O cliente Android lê linhas em thread separada e notifica quando o socket cai; não foi identificado fluxo de reconexão automática validado. O firmware anuncia o estado do Bluetooth, mas deve ser testado em cenário real.

Critério de encerramento: Ensaio documentado em quadra com desconexões intencionais, reconexão bem-sucedida e comparação entre golpes detectados no ESP32 e recebidos pelo aplicativo.

3.3. R3 — Lentidão da API ou falha de sincronização

Gatilho de acionamento: Timeout, resposta HTTP de erro, banco indisponível ou registros ausentes/duplicados após sincronizar.

Resposta/contingência: Manter gravação no Room e adiar a sincronização; retentar quando a conexão voltar. Confirmar que a repetição não duplica o histórico e que falhas de transação sofrem rollback.

Situação observada no código: SyncManager captura falhas sem apagar os dados locais; a API usa transação e inserção idempotente do histórico. Permanecem pendentes os testes ponta a ponta em falha e retorno de rede.

Critério de encerramento: Testes offline/online, reinício do MySQL, repetição do mesmo lote e sincronização entre dois celulares aprovados.

3.4. R4 — Perda de amostras I2C do MPU-6050

Gatilho de acionamento: Leitura incompleta do quadro, erro de comunicação I2C ou queda da taxa de aquisição.

Resposta/contingência: Descartar a amostra inválida, não reutilizar leituras antigas como se fossem atuais e registrar o evento. Verificar alimentação, conectores, frequência de amostragem e calibração após ajustes na raquete.

Situação observada no código: O firmware retorna falha se a leitura I2C não entregar os 14 bytes esperados. A contagem de erros e o comportamento sob mau contato precisam ser verificados em bancada.

Critério de encerramento: Ensaio controlado de mau contato concluído, sem travamento nem classificação baseada em quadro inválido; registrar taxa de falha observada.

3.5. R5 — Falha grave do firmware

Gatilho de acionamento: Reinicialização inesperada, travamento, falta de memória ou falha persistente na inicialização do sensor/Bluetooth.

Resposta/contingência: Interromper o teste, reiniciar em condição segura e regravar a versão estável se necessário. Revisar a recuperação após falha e o uso de watchdog sem afetar a temporização da aquisição.

Situação observada no código: O firmware verifica a alocação de buffers e a inicialização do MPU-6050; diante de falha nesses passos, permanece em espera. Não foi possível validar watchdog, recuperação ou teste prolongado apenas pela inspeção estática.

Critério de encerramento: Teste de inicialização a frio e execução prolongada aprovados; procedimento de recuperação testado e versão estável identificada.

3.6. R6 — Inconsistências visuais no aplicativo

Gatilho de acionamento: Texto cortado, contraste insuficiente, botão de retorno inconsistente ou regressão de layout.

Resposta/contingência: Registrar tela e passos para reproduzir, corrigir a tela afetada e executar o fluxo completo de volta à tela principal.

Situação observada no código: Há layouts e recursos de estilo compartilhados no pacote; a revisão dos arquivos fornecidos não substitui teste visual no dispositivo.

Critério de encerramento: Checklist visual dos fluxos prioritários concluído em pelo menos um dispositivo físico ou emulador e sem regressão bloqueadora.

3.7. R7 — Vulnerabilidades de corrupção de memória em dependências Python

Gatilho de acionamento: Alerta do Aikido ou de outra ferramenta sobre exploração das bibliotecas, travamento ou consumo anormal de memória ao processar imagem/vídeo, ou arquivo de mídia de origem desconhecida sendo processado.

Resposta/contingência: Interromper o processamento de arquivos de origem não confiável, atualizar as bibliotecas afetadas para as versões corrigidas e executar novamente o fluxo de visão computacional com arquivos de teste conhecidos. Se uma atualização causar incompatibilidade, fixar a versão corrigida mais próxima compatível e registrar a restrição.

Situação observada (Aikido Security): opencv-python (Crítico, DoS ou RCE por heap-based buffer overflow, esforço estimado de 30 min); pillow (Crítico, mesma classe de falha, 4 h); numpy (Médio, DoS ou RCE por dereferência de ponteiro não confiável, 1 h). Esforço total estimado: 5 h 30 min. Todos com status “New”.

Critério de encerramento: Três bibliotecas atualizadas e fixadas no requirements.txt, pipeline de visão executado sem regressão, limites de formato e tamanho de entrada aplicados e nova varredura do Aikido sem esses três achados.

3.8. R8 — Injeção de SQL em bibliotecas de acesso a dados Python

Gatilho de acionamento: Alerta do Aikido sobre PyMySQL ou pandas, consulta com resultado inesperado, entrada de usuário chegando a uma consulta SQL ou acesso anormal ao MySQL pelos componentes Python.

Resposta/contingência: Atualizar PyMySQL e pandas, revisar todas as consultas feitas pelo código Python e substituir qualquer concatenação de texto por parâmetros. Em caso de suspeita de exploração, rotacionar a senha da conta MySQL usada pelo componente e revisar os logs, seguindo a contingência de R1.

Situação observada (Aikido Security): PyMySQL (Crítico, SQL injection possível, esforço estimado de 15 min); pandas (Baixo, SQL injection possível, 1 h). Esforço total estimado: 1 h 15 min. Ambos com status “New”. No backend Node.js, as consultas parametrizadas já constam como controle existente em R1; este risco trata apenas dos componentes Python.

Critério de encerramento: Bibliotecas atualizadas, consultas do código Python revisadas e parametrizadas, conta MySQL com menor privilégio e nova varredura do Aikido sem os dois achados.

3.9. R9 — Backend Node.js sem cabeçalhos de segurança e com dependências vulneráveis

Gatilho de acionamento: Resposta HTTP sem cabeçalhos de segurança em teste (ex.: OWASP ZAP), queda do processo Node.js por erro de upload ou leitura de corpo, ou alta carga causada por requisições malformadas.

Resposta/contingência: Aplicar os cabeçalhos de segurança no Express, atualizar multer e raw-body e tratar erros em middleware para que uma requisição inválida retorne erro HTTP sem derrubar o servidor. Reiniciar o serviço e revisar logs se houver queda.

Situação observada (Aikido Security): Express não emite cabeçalhos de segurança em server.js (Alto, 45 min, com correção sugerida disponível na plataforma); multer (Alto, exceção não tratada que pode ser abusada, 30 min); raw-body (Baixo, DoS, 2 h). Esforço total estimado: 3 h 15 min. Os limites de corpo JSON e de taxa de requisições já incluídos em R1 reduzem, mas não eliminam, a exposição.

Critério de encerramento: Cabeçalhos de segurança presentes nas respostas, dependências atualizadas, teste com requisições malformadas sem queda do servidor e nova varredura do Aikido sem os três achados.

3.10. R10 — Upload de arquivos perigosos no Streamlit

Gatilho de acionamento: Aceitação de arquivo de tipo inesperado na interface Streamlit, arquivo enviado em local acessível externamente ou alerta do Aikido persistente após a atualização.

Resposta/contingência: Atualizar o streamlit para a versão corrigida, restringir os tipos e o tamanho dos arquivos aceitos e remover arquivos suspeitos já enviados. Manter a interface acessível apenas na rede local ou com autenticação até a conclusão da correção.

Situação observada (Aikido Security): streamlit (Alto, atacante pode enviar arquivos perigosos, esforço estimado de 1 h, status “New”).

Critério de encerramento: Versão corrigida instalada e fixada, teste de upload com extensão e tipo não permitidos recusado e nova varredura do Aikido sem o achado.

3.11. R11 — Configuração insegura do aplicativo Android

Gatilho de acionamento: Conexão aceita sem validação de certificado em teste, componente do app acessado por outro aplicativo sem autorização ou dado sensível presente em backup do dispositivo.

Resposta/contingência: Corrigir o AndroidManifest.xml e a configuração de rede do app, gerar nova versão e reinstalar nos dispositivos de teste. Se houver suspeita de exposição de token ou dado pessoal, rotacionar o JWT_SECRET e invalidar sessões, conforme R1.

Situação observada (Aikido Security): Todos em AndroidManifest.xml: validação inadequada de certificado SSL (Alto, 8 h); componentes Android com atributo exported ativo (Médio, 2 h); configuração de backup imprópria (Médio, 4 h). Esforço total estimado: 14 h, o maior entre os riscos novos. A exclusão do token remoto dos backups, descrita em R1, deve ser conferida em conjunto com o achado de backup.

Critério de encerramento: Comunicação com a API somente por HTTPS com certificado válido, componentes exportados apenas quando necessário e protegidos, backup sem dados sensíveis, fluxos de login e sincronização testados em dispositivo e nova varredura do Aikido sem os três achados.

3.12. R12 — SSRF e exposição de stacktrace

Gatilho de acionamento: Requisição enviada a destino não previsto (URL externa ou IP interno), mensagem de erro técnica exibida ao usuário ou alerta do Aikido persistente após a correção.

Resposta/contingência: Aplicar lista de destinos permitidos nas requisições de app.py e VisaoComputacionalClient.java, bloquear endereços internos e redirecionamentos e exibir ao usuário apenas mensagem genérica de erro, mantendo o detalhe técnico somente em log.

Situação observada (Aikido Security): possível SSRF por entrada do usuário em requisição HTTP em app.py (Médio, esforço estimado de 1 h 30 min); possível SSRF em requisição HTTP em VisaoComputacionalClient.java (Médio, 1 h); stacktrace pode ser exposto ao usuário final em Treino.java (Médio, 20 min). Esforço total estimado: 2 h 50 min.

Critério de encerramento: Requisições aceitas apenas para destinos permitidos, teste com URL externa e IP interno recusado, erro forçado sem stacktrace na tela e nova varredura do Aikido sem os três achados.

4. Monitoramento e Revisão

Frequência: revisão quinzenal, conforme o Plano de Gerenciamento de Riscos, e revisão extraordinária após incidente de segurança, perda relevante de telemetria ou alteração de arquitetura. Para R7 a R12, repetir a varredura do Aikido Security após cada correção e ao atualizar dependências.

Registro de evidências: manter uma issue por risco no GitHub Projects, com responsável, prazo, nível residual, caso de teste, resultado e link para logs ou commit. Nunca anexar senhas, tokens ou dados pessoais nos logs/prints. Para R7 a R12, a evidência de encerramento é o relatório do Aikido sem o achado correspondente, acompanhado do teste funcional descrito no critério de encerramento.

Escalonamento: R1 exige ação imediata diante de exposição de credenciais ou acesso cruzado; R2 deve ser escalado se impedir a coleta em treinos repetidos; R3–R5 devem ser escalados se houver perda de dados, travamento ou classificação baseada em amostra inválida. R6 permanece no ciclo normal, salvo se bloquear o fluxo principal. R7 e R8 (severidade crítica) têm prioridade sobre os demais riscos técnicos e devem ser escalados se a atualização causar regressão ou não puder ser concluída no prazo; R9 a R11 devem ser escalados

se o backend ou o aplicativo forem expostos fora da LAN antes da correção; R12 segue o ciclo normal, salvo se SSRF ou exposição de stacktrace for reproduzido em teste.

Status: Não iniciado; Em andamento; Mitigação parcial (testes pendentes); Concluído (evidência aprovada); Cancelado (com justificativa). O risco só será encerrado após validação e registro da evidência.

Recursos: manter a reserva de 15% das horas de desenvolvimento para auditoria, testes de estresse Bluetooth/ESP32 e validações de segurança, conforme o plano-base.